
Z.AI SECURITY AUDIT · v0.6.3 · COLOR TEAM

Bitcoin Easy Signer

A five-agent panel plus a referee re-audited the remediation release: every prior finding verified fixed, the vendored cryptography proven against Bitcoin's test vectors, and a fresh attack wave finding no breach.

Grade: Yellow — one documented process step from Green.

Prepared by Z.ai (GLM-5.3, via ZCode) · Red,

Blue, Orange, Copper, Amber and the White

referee · 2 October 2026

Contents

Document Control

1

The Grade: Yellow — One Documented Step from Green

2

The Four Questions That Matter

2

The Prior Audit's Findings: All Fixed

3

The Panel

3

What This Audit Did Not Do

4

Appendix — Findings Ledger (BESA-26...44)

4

Document Control

Field	Detail
Report title	Z.ai Security Audit — Bitcoin Easy Signer v0.6.3 — the Color Team report
Report identifier	DOC ZAI-BESA-063 · designed edition of the report published at releases/AUDIT-ZAI-0.6.3.md
Subject	Bitcoin Easy Signer v0.6.3 — remediation release following the v0.6.2 audit (25 findings)
Version examined	Tag v0.6.3 · commit f19bc460a2cb64590e8e37268b5be1df1a1f84b0 · published 2 October 2026
Auditor	Z.ai (GLM-5.3, via ZCode) — five-agent Color Team panel plus a referee; charters and grade rules locked in writing before the build was examined
Grade	Yellow — no critical or high findings; all five Green conditions met except one clause: a single open Medium process finding (see The Grade)
Classification	Public — released to the project repository

Findings carry stable identifiers: BESA-01...25 from the v0.6.2 audit (all actionable items verified fixed at this commit), BESA-26...44 new in this cycle, final numbering fixed by the referee.

The Grade: Yellow — One Documented Step from Green

All five Green conditions were met except one clause. There are no critical or high findings; every one of the 25 prior findings is verified fixed, each pinned by a regression test that fails if the fix is reverted; the security-critical core — the signature-verification and transport modules — is byte-identical to the previously audited version, with the transaction constants unchanged; and a dedicated attacker-agent found no breach. One open Medium finding holds the grade back. The locked rules define Green by five conditions and Yellow by “open medium findings beyond the owner's written acceptance”; the referee ruled the text must be read so its Yellow clause can ever apply. It is a process finding, not a code defect.

25/25 PRIOR FINDINGS FIXED OR CLOSED	0 CRITICAL OR HIGH FINDINGS	262 TESTS RE-RUN AND PASSING	6 AGENTS: FIVE COLORS + REFEREE
--	---	--	---

The finding that holds the grade (BESA-33, Medium). v0.6.3 was published through the project's documented manual procedure rather than the build pipeline's automated publish gates: the release appeared eleven minutes after the non-publishing candidate build finished, so the machine-enforced checks (tag guard, re-hash-before-publish, unsigned-build refusal) never executed for the publication event. The panel verified every mitigation — published files byte-identical to the candidate run's checksums; the tag pointing at the exact audited commit; open disclosure in the release notes; the procedure written down — but a stated gate that did not run is exactly what a supply-chain audit exists to report.

The path to Green is a single step, then a re-run of the panel: either publish one future release through the automated gates, or record a dated owner acceptance of the manual path as a documented residual risk. Nothing else stands between this audit's evidence and a Green grade.

The Four Questions That Matter

Question	Verdict
Could this software send bitcoin somewhere the operator did not approve?	No — no such path was found. A dedicated attacker-agent, deliberately kept ignorant of prior conclusions, attacked every change since v0.6.2 and every classic surface: crafted device paths, races on the payment review, counterfeit-device spoofing, hostile explorer data, CI bypasses, supply-chain substitution. Every attempt was refused, fail-closed.
Could it expose a seed phrase, private key, or device PIN?	No. The application has no code path that reads, stores, or transmits key material of any kind — re-verified against all changed code.

Question	Verdict
Could a remote party, a dependency, or a local process alter a transaction without the operator seeing it?	No — not on any path this software executes. The deepest new risk this release took was vendoring its own cryptography library; the panel proved the vendored build is the upstream library plus exactly two declared lines (a version label and a one-line correctness fix the upstream project has not yet merged), validated byte-exact against Bitcoin's official test vectors. The application's own verify-then-finalize remains the only finalizer in use.
What should be done first?	Publish the next release through the automated gates — the one item between this report and a Green grade.

The Prior Audit's Findings: All Fixed

All 22 actionable findings from the v0.6.2 audit are verified fixed at this commit, each with file-and-line evidence and a reverting regression test. The referee independently re-derived the six most safety-critical rows — the hash-pinned install order, the step-local signing secrets, the publish gates, the dual-named USB library, the sign-time device binding, and the parser error handling — and found each exactly as claimed. Three informational findings required no action; one optional enhancement (release attestations) remains open by choice. Headline repairs, all verified in the shipped product:

- The release pipeline installs every dependency hash-verified before any signing credential exists.
- The USB library is vendored, dual-named, loaded deterministically (proven on a Homebrew-equipped Mac with the shipped binary's own self-check), and its shipped digests are in the bill of materials.
- Signer identity is re-verified at the exact moment of signing, not just when devices are scanned.
- The cryptography library's known defects — including one upstream has not fixed — are repaired in a vendored build whose every byte is accounted for against the upstream commit.

The Panel

Five specialists dispatched simultaneously, each with one lens and no sight of the others' findings; the referee saw everything and gated this publication.

	Agent	Verdict	Report
	Red	The attacker — no breach found	Attacked every changed surface plus the classics; every attempt refused. Residual: a physical device-swap window of seconds, bounded to denial-of-service — no forged signature can survive verification.
	Blue	The defender — defenses hold	All nine stated controls verified end-to-end and pinned by tests; all 25 prior findings tracked to fixes. Gaps: three refusal branches lack regression pins (fail-closed by inspection).
	Orange	The cryptographer — sound as used	Vendored library = upstream at commit 2b375a plus exactly two declared lines; all BIP vectors byte-exact; the library's own 121-test suite passes. Future duty: the private patch must be re-audited at every library update.

	Agent	Verdict	Report
	Copper	The hardware specialist — transport sound	Both USB library names ship inside the signed binary; loading deterministic and fail-closed; provenance byte-exact to official libusb 1.0.30; sign-time binding lock-consistent. Note: the vendored binary's trust anchors are repo-circular — a future release could rebuild from the vendored official source.
	Amber	The supply-chain inspector — chain holds	Every pipeline claim verified with evidence, with one finding: the manual publication (BESA-33). The source archive is byte-identical to the tagged tree, all 117 files, nothing that should not be public.
	White	The referee — verified, graded, gated	Re-derived every load-bearing claim personally; all verified, three minor citation drifts corrected; merged the ledger to BESA-26...44; applied the locked grade rules mechanically, in neither direction. Publication approved with mandatory facts.

What This Audit Did Not Do

- No panel agent attached a hardware device; the owner's physical practice-network payment (two vendors, both signatures verified by the app, broadcast accepted) is taken as reported evidence, recorded in the release records without wallet details.
- No transaction was created or broadcast by the panel on any network.
- The automated publish workflow has never executed a publication for any release — that is the substance of the grade's one finding.
- “No finding” means “none found within this coverage,” not “none exist.”

Appendix — Findings Ledger (BESA-26...44)

Final numbering fixed by the referee after the specialists' independent counts collided. Prior-cycle BESA-01...25: all actionable items verified fixed at this commit.

ID	Severity	Finding
BESA-33	Medium	v0.6.3 published via the documented manual path; automated publish gates did not run for the publication event (bytes verified identical to the candidate; disclosed; conversion path defined)
BESA-26	Low	Physical device swap in the verify-to-sign window (seconds) receives the reviewed PSBT; bounded to disclosure/DoS
BESA-27	Low	Three sign-endpoint refusal branches lack regression pins (no-binding, stale-binding, verify-failure wiring); fail-closed by inspection
BESA-28	Low	Broadcast returned-txid-mismatch branch untested directly (gui.py:942-946)
BESA-29	Low	hwi entitlement + onefile extraction surface; entitlement may now be droppable; stale build comment
BESA-30	Low	Vendored libusb binary's trust anchors are repo-circular (source correspondence hash-verified, never rebuilt)

ID	Severity	Finding
BESA-31	Low	SBOM embit entry carries no hash; its purl is symbolic (local build) — authenticate via the hash-locked wheel
BESA-32	Low	Seconds-wide tag-check/publish TOCTOU (needs concurrent push access)
BESA-34	Info	Stale signer-binding cleanup (cryptographically unusable; fresh 144-bit review IDs)
BESA-35	Info	CI provisioning secrets visible in argv on ephemeral single-tenant runners
BESA-36	Info	Bundled-library assertion runs in the build preflight, not on every command
BESA-37	Info	Inherited secp256k1 loader may find an external library (blocked by hardened runtime in the shipped app)
BESA-38	Info	Project carries an unmerged-upstream crypto patch (spec-correct, tested); re-audit at every future library update
BESA-39	Info	Same upstream bug remains in vendored Liquid code — unreachable (no imports)
BESA-40	Info	Library-layer address quirks (uppercase bech32, unknown HRP) — neutralized by the app's re-encode check
BESA-41	Info	Pre-signing device check binds public data only — inherent; capped by on-device approval and signature verification
BESA-42	Info	In-tag status stamps remain prepublication (documented behavior; archive identical to the tagged tree)
BESA-43	Info	Hashless install hints remain in developer documentation only; CI path clean and test-enforced
BESA-44	Info	Candidate-run evidence listed open at the tag — resolved on main immediately after (run recorded; owner acceptance recorded)

Audit performed 2 October 2026 by Z.ai on the public repository and published artifacts only. The grade rules were locked in writing before the audit began and applied as written. No wallet material, addresses, or transaction identifiers appear in this report. An audit is not a certification of safety; it is dated evidence about one revision, and its coverage limits are stated above.